‘외워서’ 끝내는 SSL과 암호기술 이론

당장 암호학을 전공할 수 없다면

그냥 외워라!

널널한 개발자 최호성 (cx8537@naver.com)

YouTube: 널널한 개발자 TV

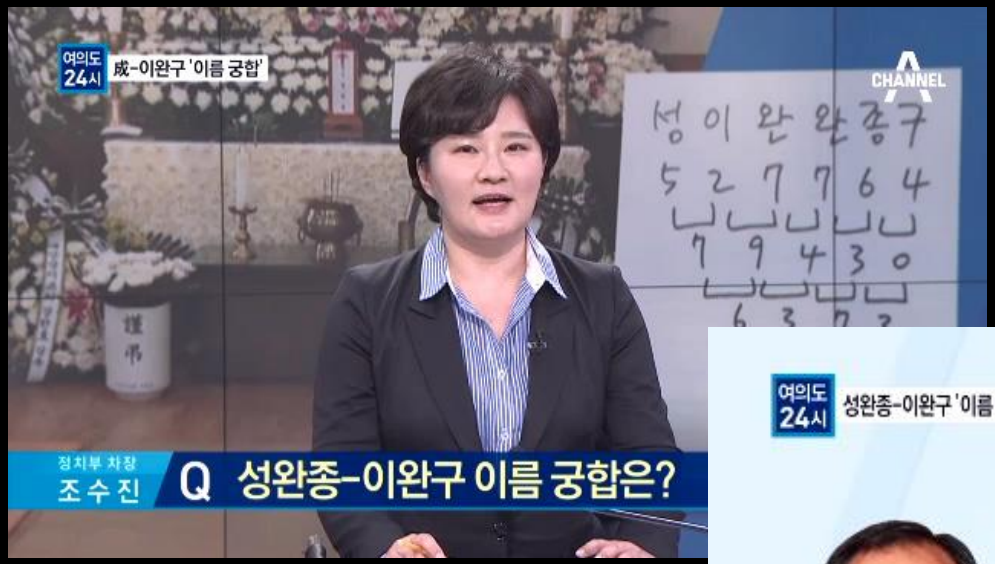
교육목표

1. Hash, Checksum에 대해 이해한다.
2. 대칭키, 비대칭키 차이를 이해한다.
3. PKI기술의 원리를 이해한다.
4. HTTPS의 작동원리를 이해한다.
5. SSL 인증서 검증방법을 이해한다.

수강에 앞서

1. **산술 연산**을 할 수 있다.
2. 2진수, 16진수 진법변환 요령을 안다.
3. 웹 서비스의 구조를 어느 정도 안다.
4. 디지털 서명 등 PKI 기술이 사용되는 기술분야에 대해 들어본 경험이 있다.

이름 궁합, Checksum, Hash



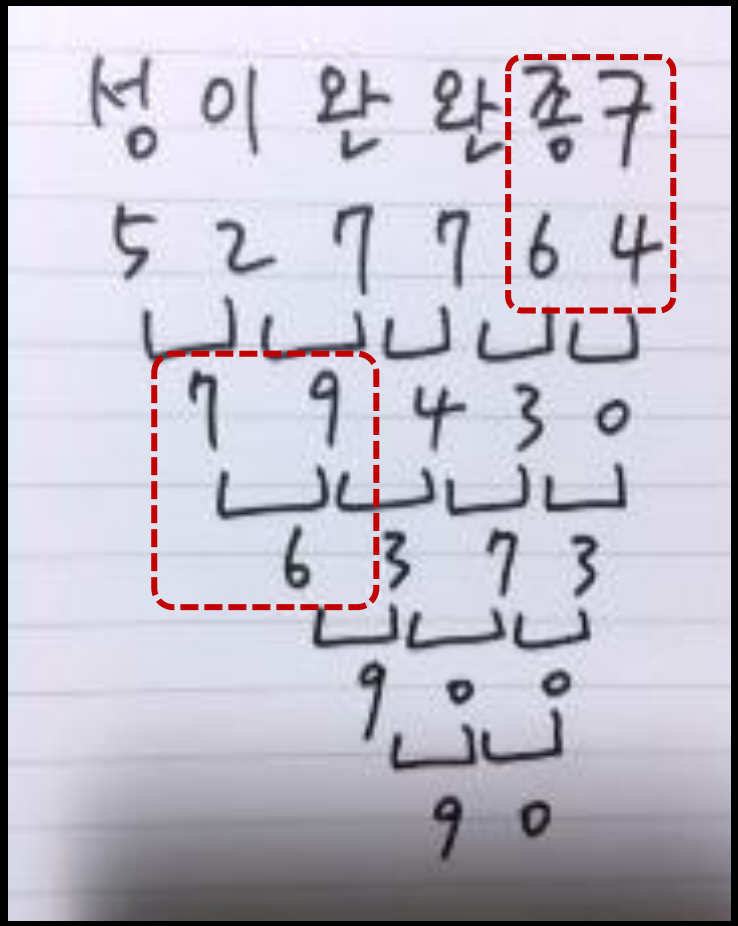
https://www.hani.co.kr/arti/society/media/687955.html (2015-04-22 한겨레)

Checksum(검사합)

- 데이터의 오류 여부 확인 방법으로 널리 사용된다.
- 일정 자릿수를 정하고 범위를 넘는 자리 올림은 버려서 자릿수를 유지한다.

Checksum(검사합)

- 7 + 9는 16이다.
- 자리올림 1을 버리면 결과는 6이다. 같은 원리로 3 + 7은 0이 된다.
- 결국 '성이완완종구'라는 문자열에 대한 최종결과는 90이다.
- 90을 근거로 '성이완완종구'라는 원본 문자열을 복원하는 것은 불가능하다. (Hash)
- 획수를 알아도 원본문자를 정확히 알 수는 없다. (Hash)



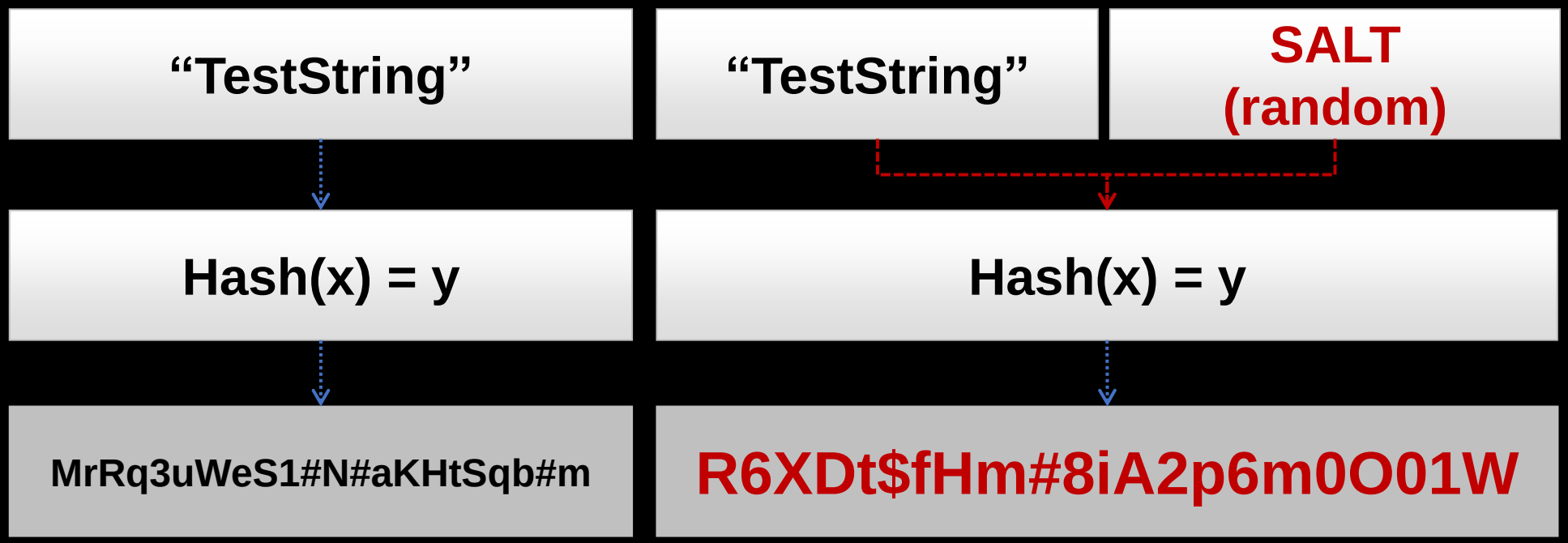
Hash (함수) 의 특징

- 단방향성
- 입력 값의 크기와 상관 없이 **결과 값의 길이(혹은 크기)가 일정**
- 데이터 무결성 확보와 관련해 IT기술 전반에서 사용된다.

대표적인 Hash 알고리즘

- MD-5
  패스워드 단방향 암호화에 사용금지
- SHA-1
- SHA-128, 256, 384, 512

MD-5 해시 결과


“TestString”
“TestString”
SALT
(random)
Hash(x) = y
Hash(x) = y
MrRq3uWeS1#N#aKHtSqb#m
R6XDt$fHm#8iA2p6m0O01W

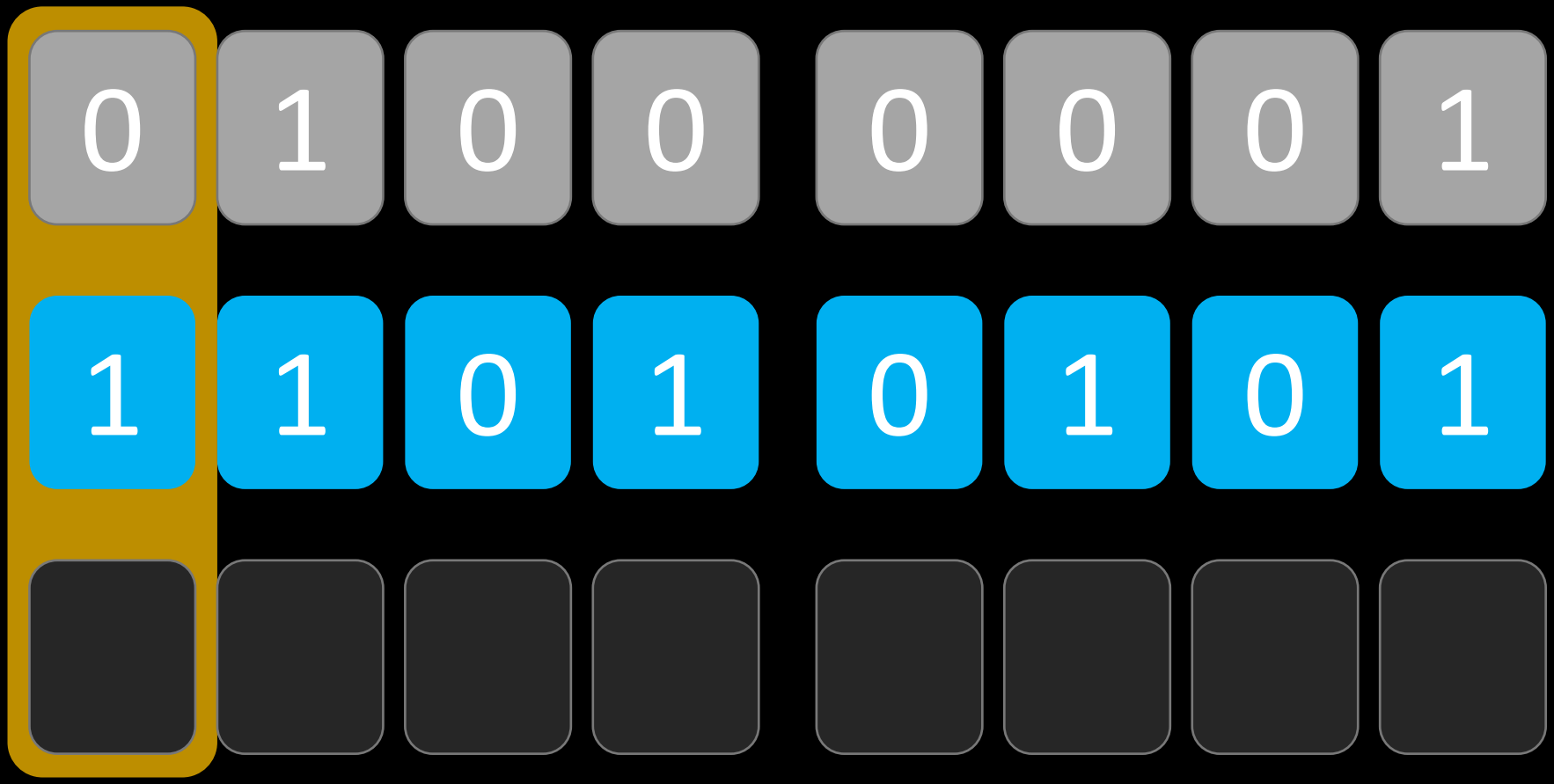
대표적인 Hash 기술 활용예

- **무결성** 확보
  - 인증서 검증
  - 디지털 포렌식
  - 디지털 서명 (Hash + PKI)
- 패스워드 단방향 암호화
- **블록체인**

대칭키 (Symmetric key)

- **키 하나로 암호화/복호화를 모두 수행**하는 방식.
- **비대칭키 방식에 비해 효율적**이다.
- DES, 3DES, SEED-128, ARIA, AES-128, AES-256 알고리즘이 유명하다.

대칭키 (Symmetric key)



각 bit별 XOR 연산 결과는?

비대칭키 (Asymmetric key)

- 한 쌍의 키가 서로 상호작용하는 구조를 갖는다.
- **두 키 중 하나로 암호화 하면 쌍을 이루는 다른 키로 복호화 한다.**
- 보통 **Public key와 Private key**로 구분하며 PKI(Public Key Infrastructure) 기술의 근간을 이룬다.
- RSA-2048, ECC 알고리즘이 있다.

비대칭키 (Asymmetric key)

$$65 \wedge 5 \bmod 323 = \underline{12}$$

$$\underline{12} \wedge 29 \bmod 323 = 65$$

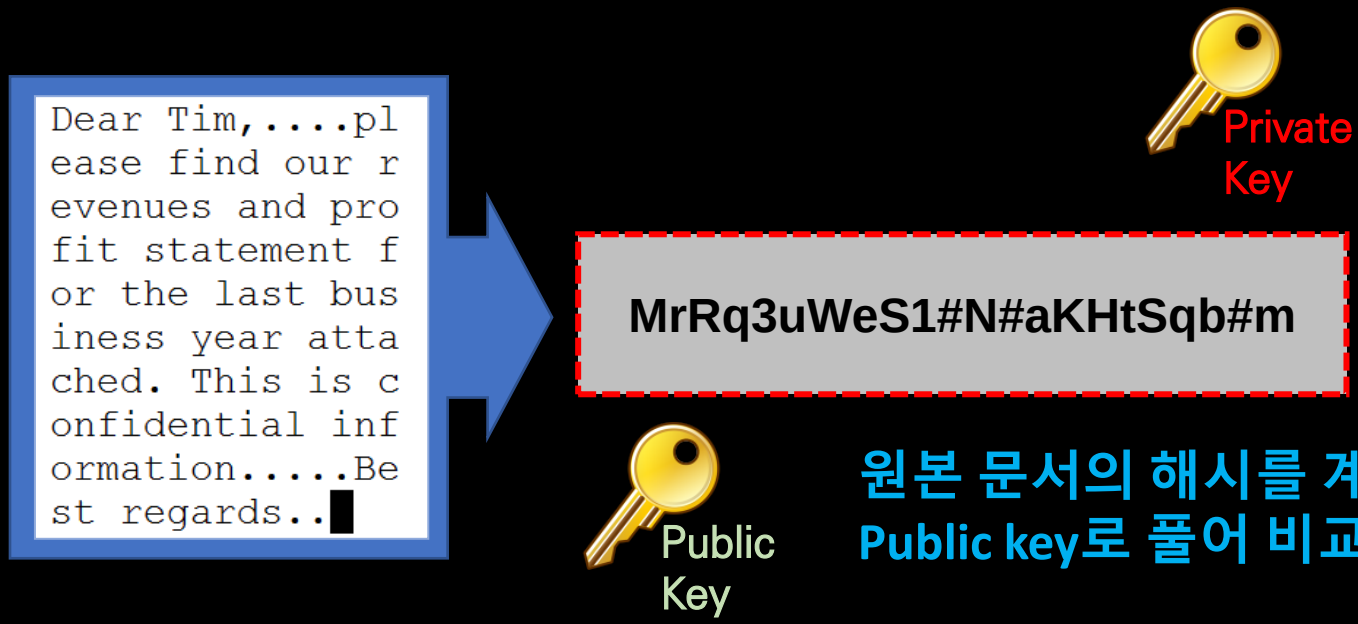
평문 숫자가 65(대문자 A)이고 암호화 키는 5, 복호화 키는 29, Modulus가 323

비대칭키 (Asymmetric key)

- 12 ^ 29는 19,781,359,483,314,150,527,412,524,285,952 이다.
- 12 ^ X mod 323 = 65에 대한 X를 찾으면 암호체계를 무력화 할 수 있다! (feat. 양자역학 컴퓨터)

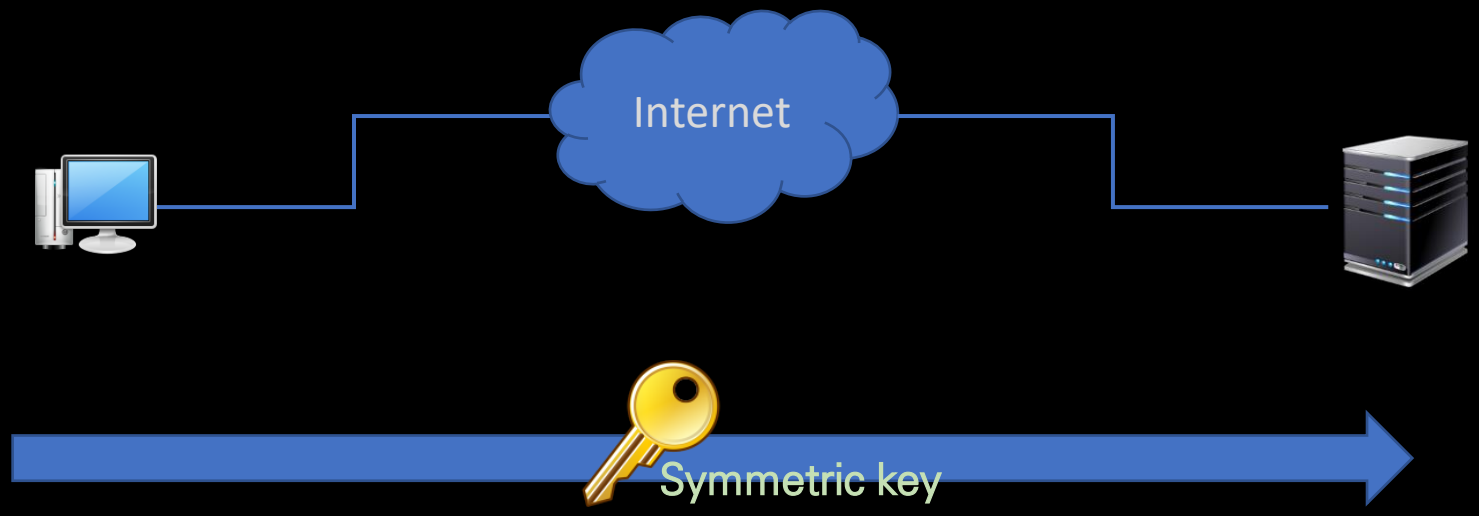
디지털 서명이란?

Private key로 해시 결과를 암호화 하는 것이다!



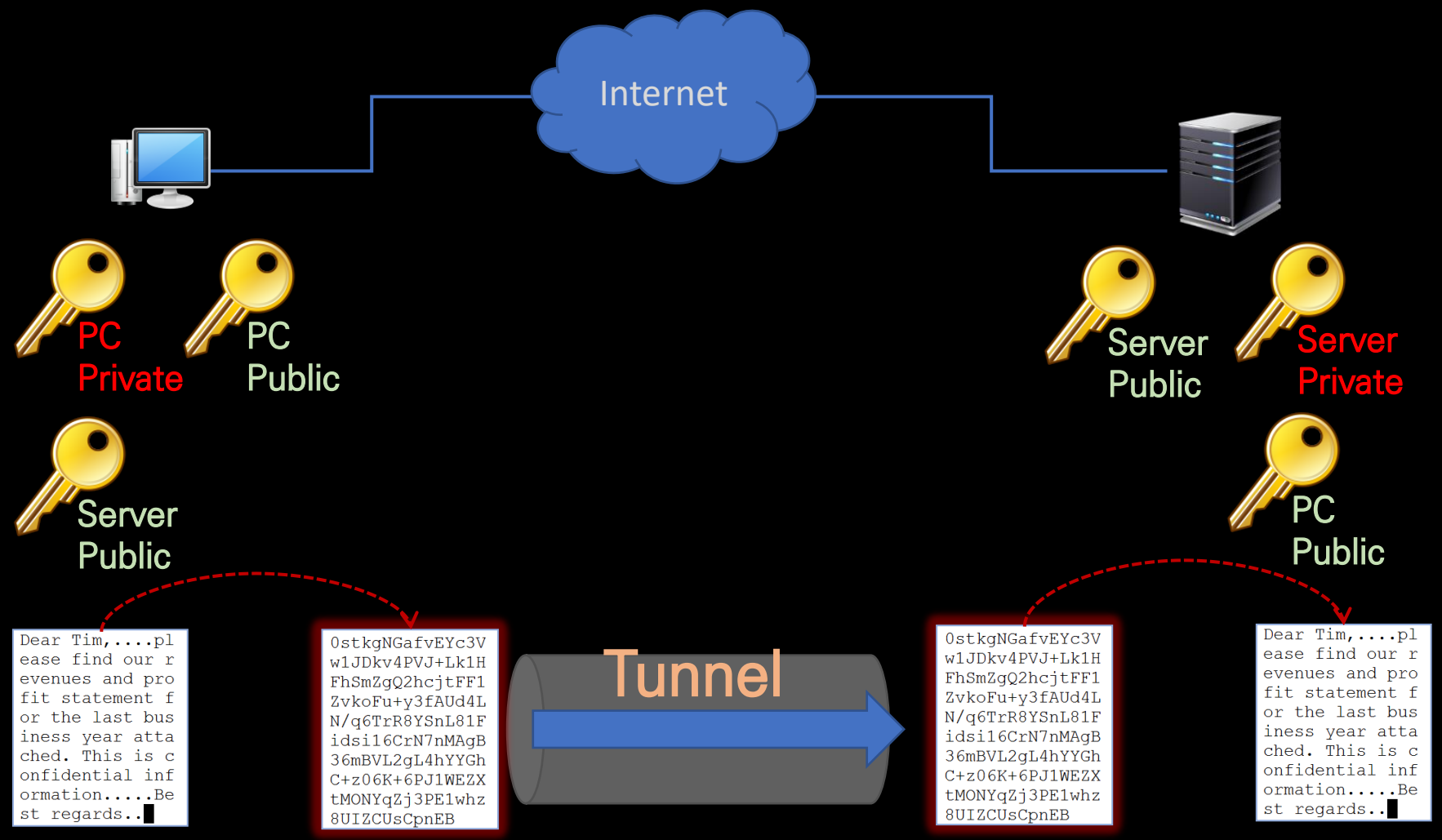
원본 문서의 해시를 계산하고
Public key로 풀어 비교

대칭키 인터넷 환경 문제

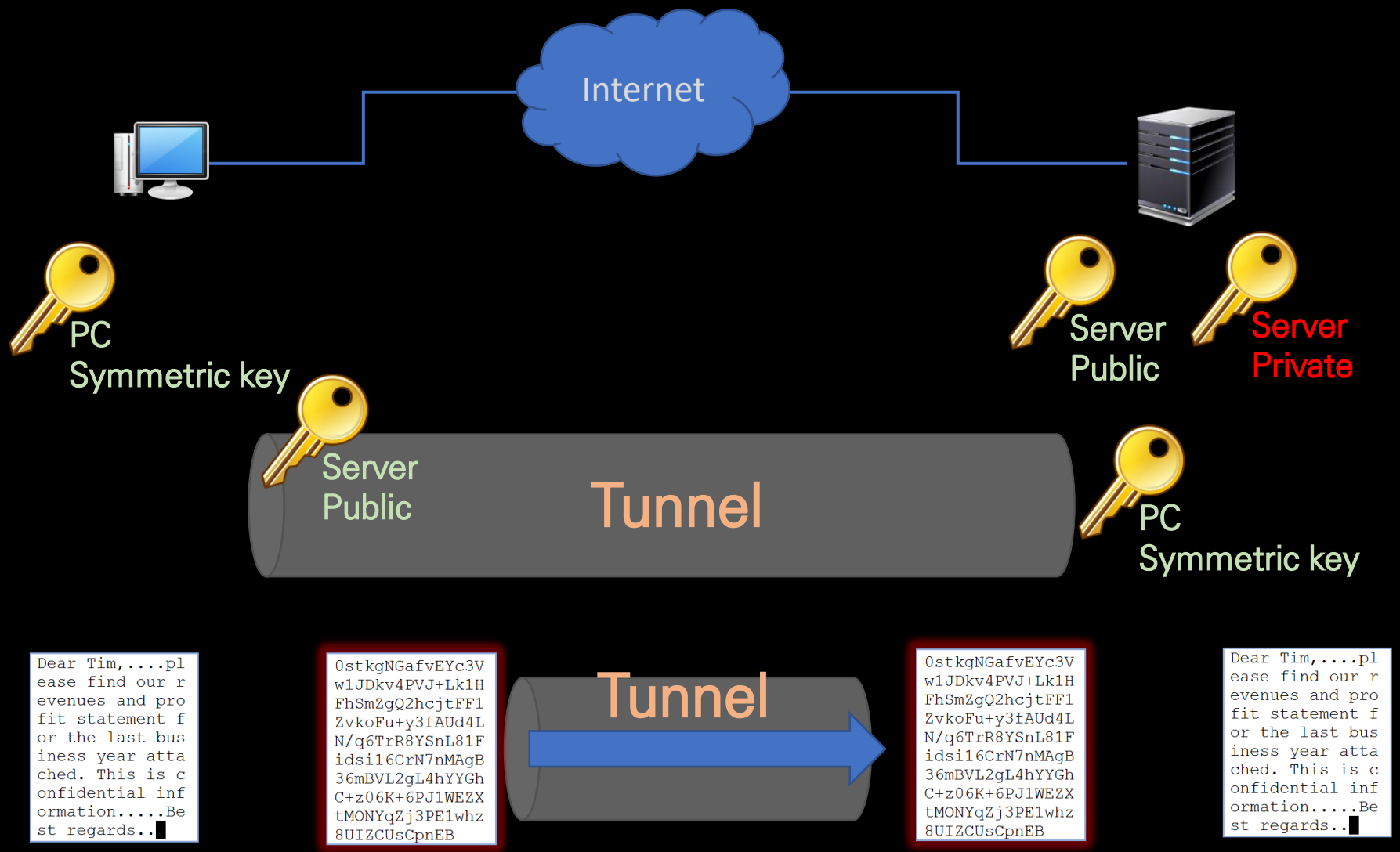


Key도 '정보'이다. 이 정보는 어떻게 안전하게 보낼 것인가?

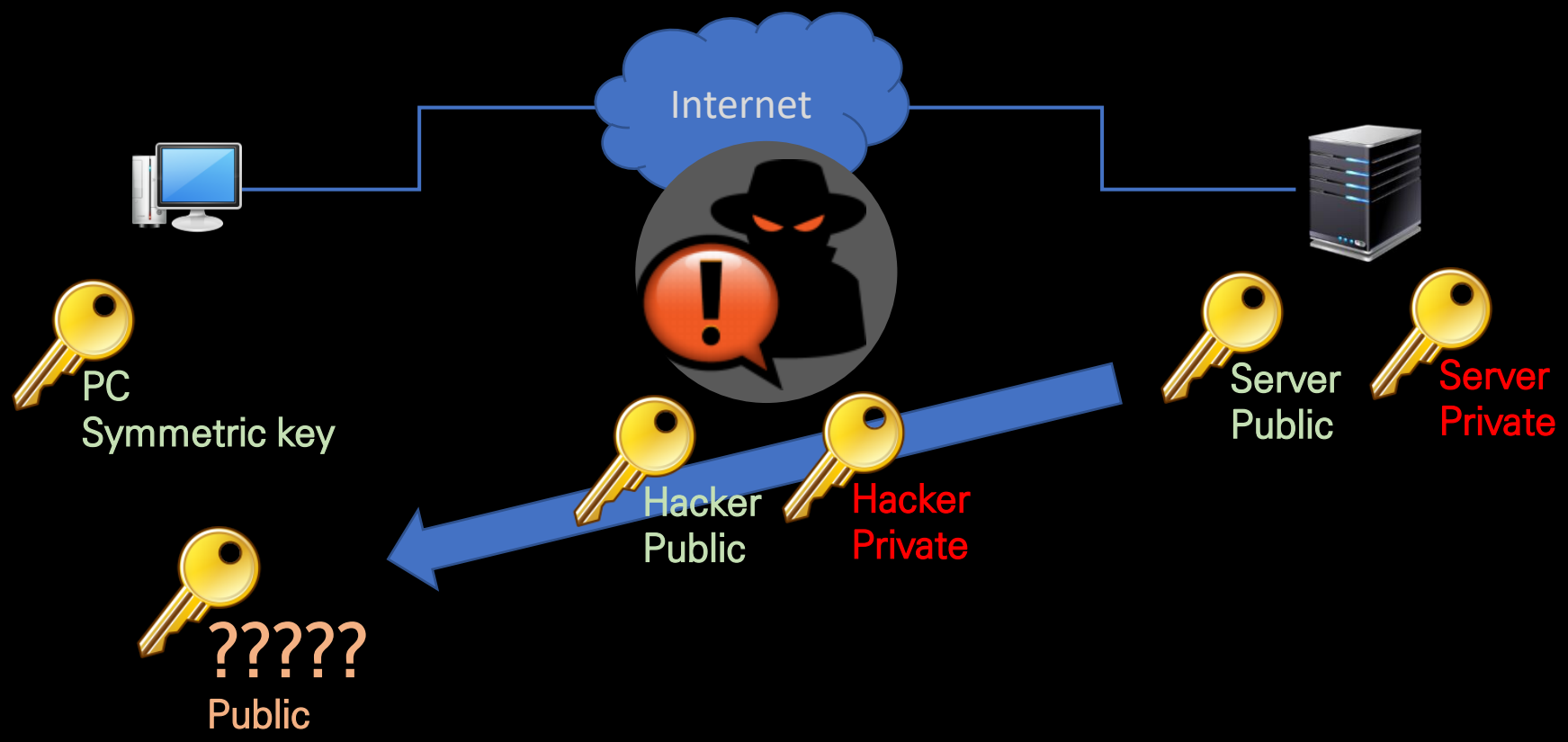
비대칭키로 해결


Internet
PC
Private
PC
Public
Server
Public
Server
Public
Server
Private
PC
Public
Dear Tim,....please find our revenues and profit statement for the last business year attached. This is confidential information.....Best regards..
0stkgNGafvEYc3Vw1JDkv4PVJ+Lk1HFhSmZgQ2hcjtFF1ZvkoFu+y3fAUd4LN/q6TrR8YSnL81Fidsi16CrN7nMAgB36mBVL2gL4hYYGhC+z06K+6PJ1WEZXtMONYqZj3PE1whz8UIZCUsCpnEB
Tunnel
0stkgNGafvEYc3Vw1JDkv4PVJ+Lk1HFhSmZgQ2hcjtFF1ZvkoFu+y3fAUd4LN/q6TrR8YSnL81Fidsi16CrN7nMAgB36mBVL2gL4hYYGhC+z06K+6PJ1WEZXtMONYqZj3PE1whz8UIZCUsCpnEB
Dear Tim,....please find our revenues and profit statement for the last business year attached. This is confidential information.....Best regards..

혼합 사용으로 효율 극대화

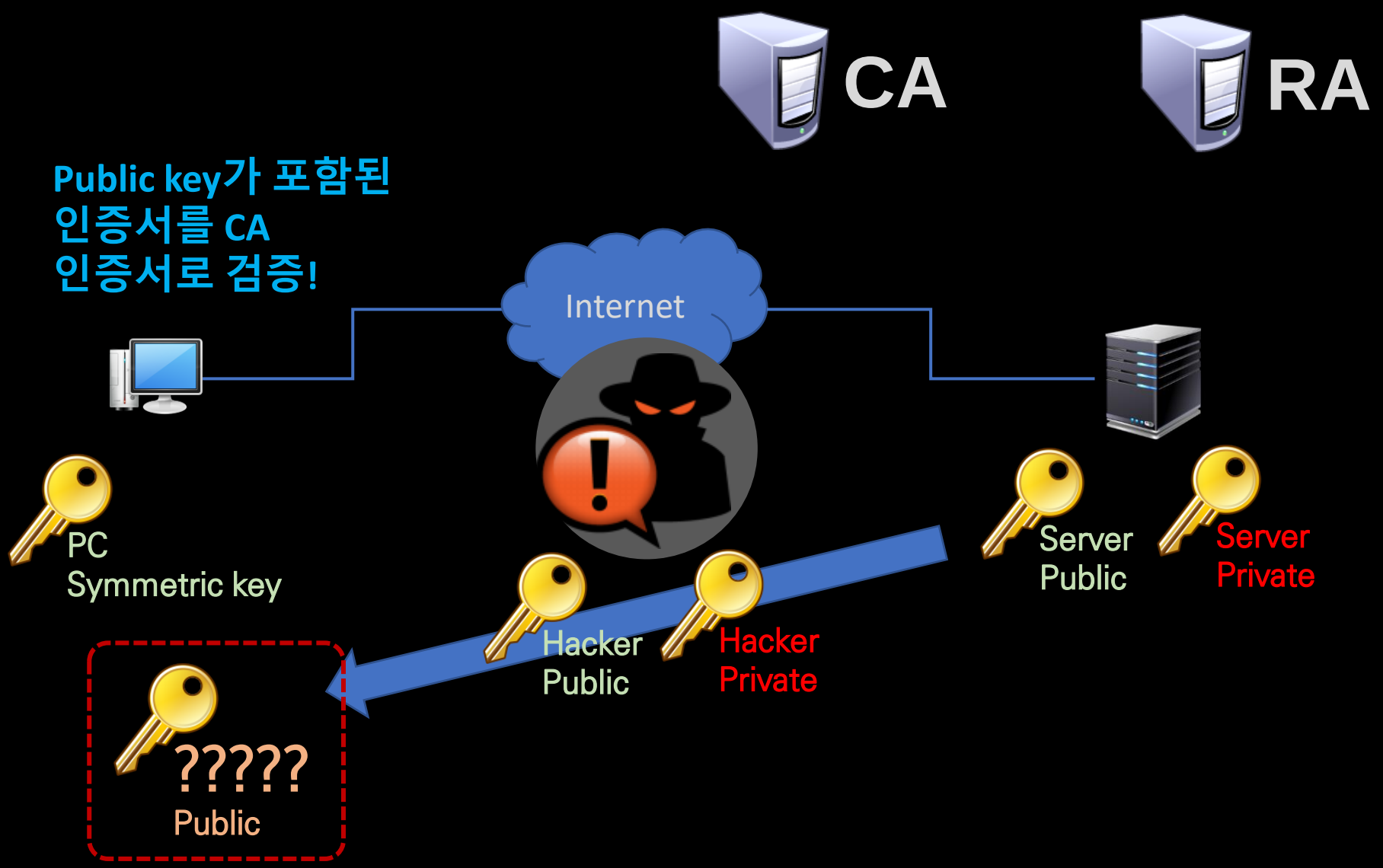


수신한 Key를 신뢰할 수 있는가?



PC가 수신한 Public key는 서버가 보낸 것이라 확신할 수 있는가?

수신한 Key를 신뢰할 수 있는가?



PKI 인증체계

- PAA(Policy Approval Authorities, 과학기술정보통신부) : 공인 인증서에 대한 정책을 결정하고 하위 기관의 정책을 승인하는 기관이다. 우리나라는 미래창조과학부가 담당한다.
- PCA(Policy Certification Authorities, 정책인증기관) : RootCA를 발급하고 기본 정책을 수립하는 기관으로, 우리나라의 KISA(Korea Information Security Agency, 한국정보보호진흥원)가 여기에 해당한다. RootCA는 모든 인증서의 기초가 되는 인증서를 보유하고 있으며, 인증서에 포함된 공개키에 대응되는 개인키로 생성한 자체 서명 인증서를 사용한다.

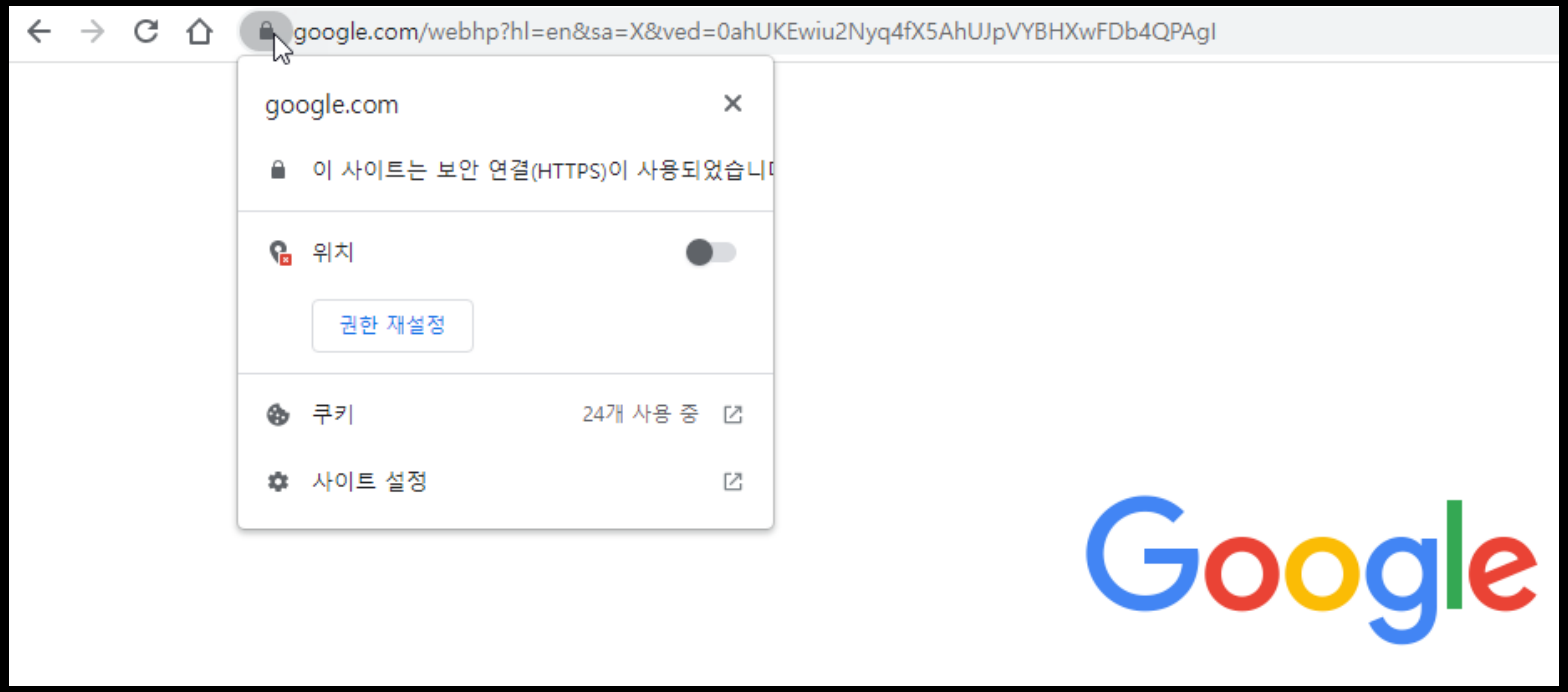
PKI 인증체계

- CA(Certification Authority, 인증기관) : PCA의 하위 기관으로 인증서 발급과 취소 등의 실질적인 업무를 하는 기관이다. yessign(금융결제원), NCA(한국전산원) 등이 이에 속하며, 상호 간 신뢰한다.
- RA(Registration Authority, 등록기관) : 사용자의 신분을 확인하고 CA 간 인터페이스를 제공하는 기관이다.

PKI 인증체계

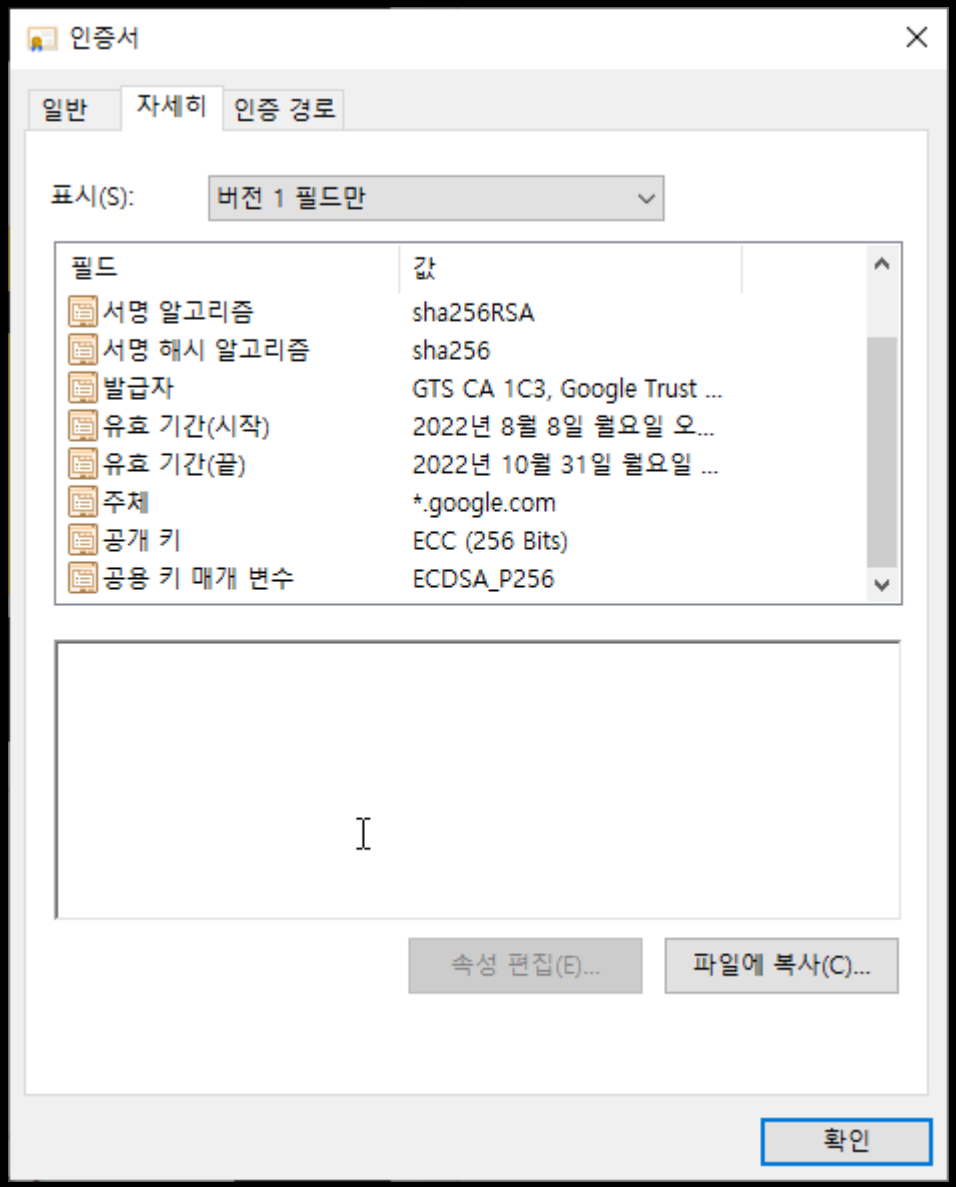
CA의 Private key로 Hash결과가 암호화 되어 있으며 검증 과정에서는 PC에 사전 배포된 CA Public key(기관 인증서에 포함)로 암호를 풀어 검증할 수 있다.

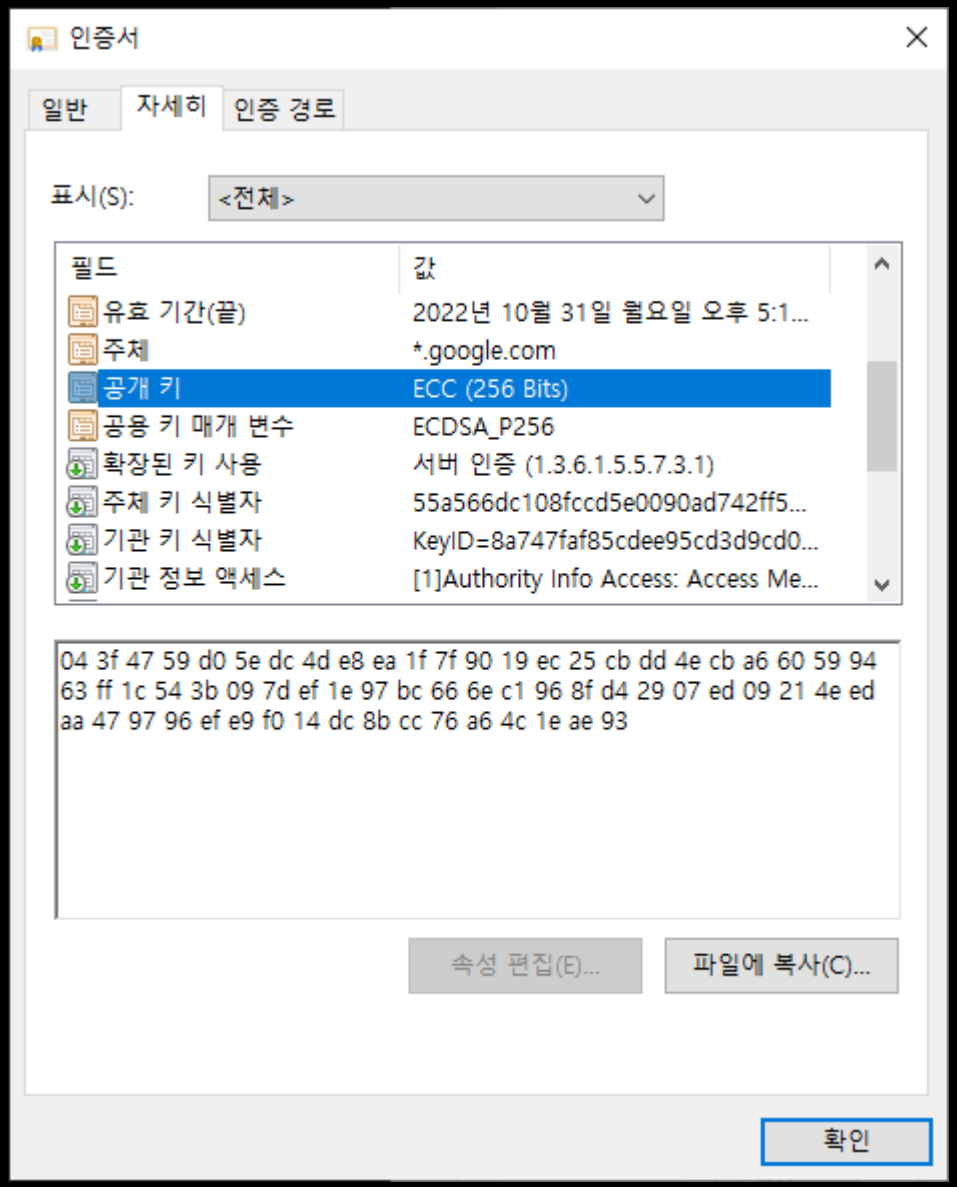
SSL 인증서



SSL 인증서를 검증하는 방법은 인증서를 발급한 CA의 인증서에 포함된 Public key를 이용해 SSL 인증서 Hash 결과를 복호화 하면 된다!

SSL 인증서

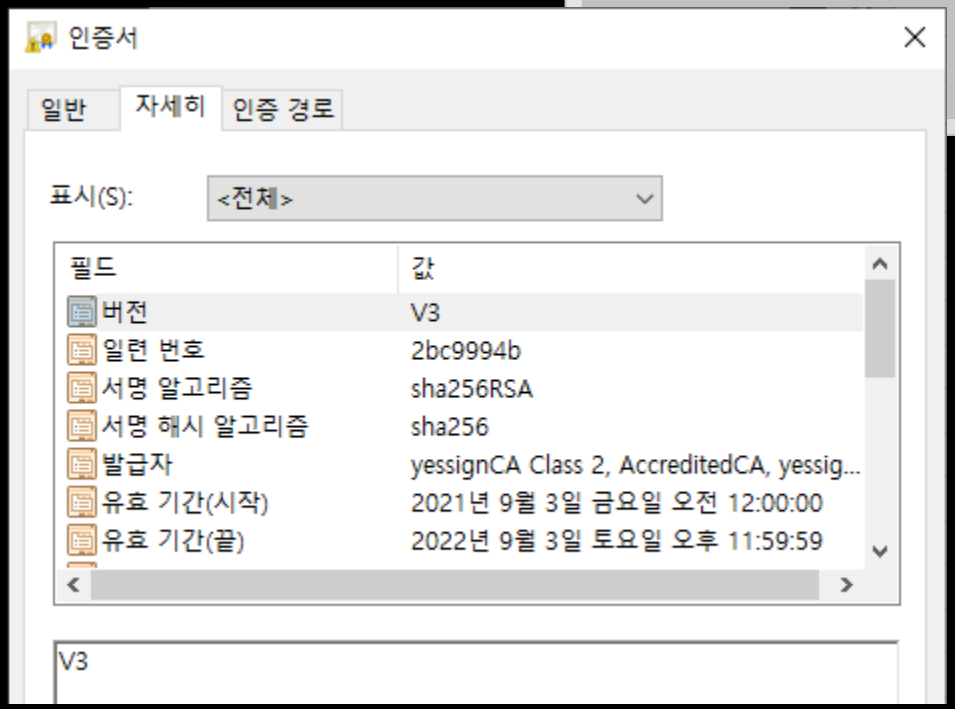

인증서
일반
자세히
인증 경로
표시(S):
버전 1 필드만
필드
값
서명 알고리즘
sha256RSA
서명 해시 알고리즘
sha256
발급자
GTS CA 1C3, Google Trust ...
유효 기간(시작)
2022년 8월 8일 월요일 오...
유효 기간(끝)
2022년 10월 31일 월요일 ...
주체
*.google.com
공개 키
ECC (256 Bits)
공용 키 매개 변수
ECDSA_P256
속성 편집(E)...
파일에 복사(C)...
확인

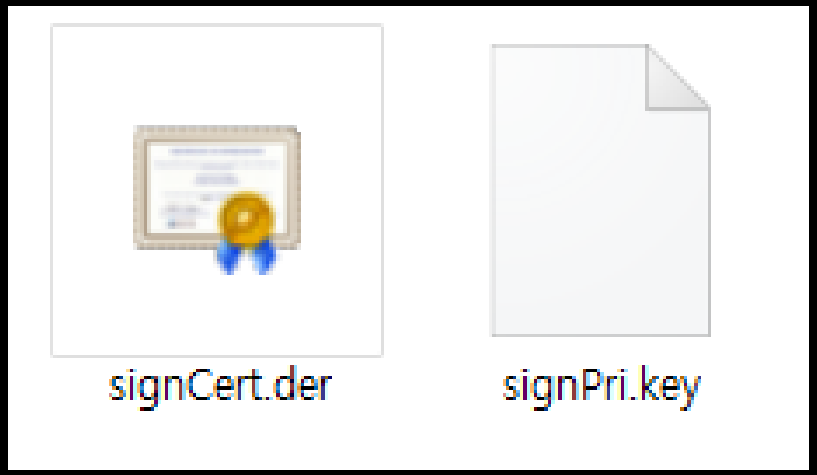

인증서
일반
자세히
인증 경로
표시(S):
<전체>
필드
값
유효 기간(끝)
2022년 10월 31일 월요일 오후 5:1...
주체
*.google.com
공개 키
ECC (256 Bits)
공용 키 매개 변수
ECDSA_P256
확장된 키 사용
서버 인증 (1.3.6.1.5.5.7.3.1)
주체 키 식별자
55a566dc108fccd5e0090ad742ff5...
기관 키 식별자
KeyID=8a747faf85cdee95cd3d9cd0...
기관 정보 액세스
[1]Authority Info Access: Access Me...
04 3f 47 59 d0 5e dc 4d e8 ea 1f 7f 90 19 ec 25 cb dd 4e cb a6 60 59 94
63 ff 1c 54 3b 09 7d ef 1e 97 bc 66 6e c1 96 8f d4 29 07 ed 09 21 4e ed
aa 47 97 96 ef e9 f0 14 dc 8b cc 76 a6 4c 1e ae 93
속성 편집(E)...
파일에 복사(C)...
확인

X.509 공인 인증서 구조

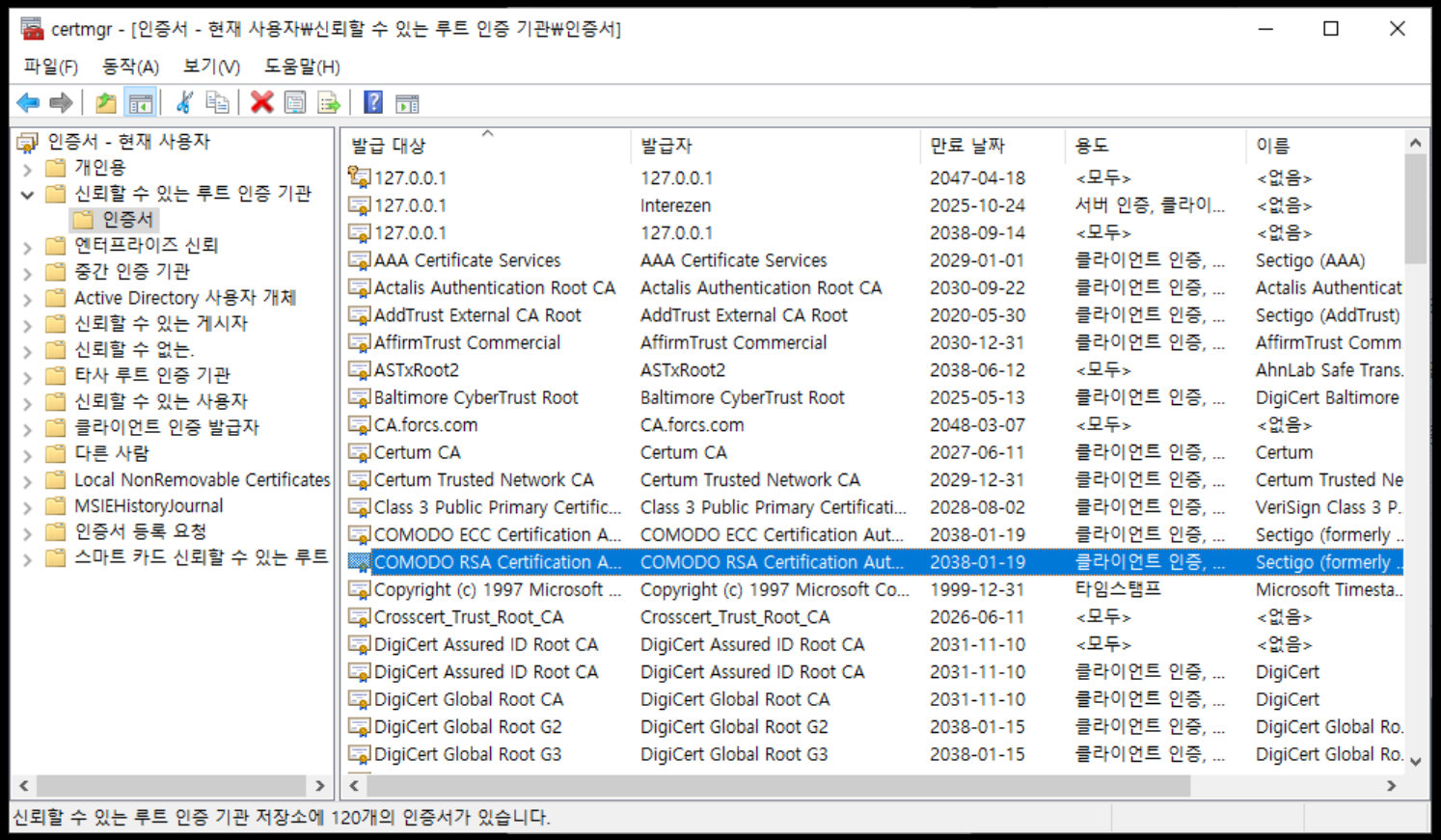
Digital certificate

User Information	Public Key	Digital sign of CA





certmgr.msc



CA의 Private key로 Hash결과가 암호화 되어 있으며 검증 과정에서는 PC에 사전 배포된 CA Public key(기관 인증서에 포함)로 암호를 풀어 (SSL 인증서를) 검증할 수 있다.